IT & INFORMATION SECURITY POLICIES

Enterprise Security Incident Response Guide & SRE Runbook

Severity Matrix, Incident Commander Roles, Triage, and Containment Playbook

Classification: Confidential **Version:** 3.5 **Owner:** Security Operations Center (SOC) **Standard:** Google SRE / NIST 800-61

1. Framework and Philosophy

The Apex Security Incident Response Guide outlines the standard operational procedures for identifying, triaging, containing, eradicating, and recovering from cybersecurity incidents and operational outages. Adapted from **Google Site Reliability Engineering (SRE) incident response practices** and **NIST SP 800-61 Rev. 2**, Apex champions a *blameless incident response culture* focused on rapid remediation and systemic learning.

2. Incident Severity Classification Matrix

Severity	Impact Criteria	Initial Response SLA	Required Incident Roles
SEV-0 (Critical)	Active data breach, ransomware, root infrastructure compromise, total customer outage.	< 5 Minutes (24/7)	Incident Commander (IC), Ops Lead, Comms Lead, CISO, Legal Counsel.
SEV-1 (High)	Significant service degradation, suspected account takeover of privileged user, partial database failure.	< 15 Minutes	Incident Commander, Ops Lead, Comms Lead, On-call SRE.
SEV-2 (Medium)	Isolated malware detection on employee laptop, abnormal rate of failed logins, non-critical service bug.	< 1 Hour	Security Operations Engineer, IT Support Lead.
SEV-3 (Low)	Phishing email reported without execution, minor configuration drift, low-risk vulnerability scan item.	< 4 Hours	Security Analyst on duty.

3. Incident Response Lifecycle and Action Steps

1. **Preparation:** Maintain pre-configured incident bridge channels, forensic toolkits (LiME, Volatility, AWS Athena log queries), and on-call rosters via PagerDuty.
2. **Identification & Declaration:** Any engineer or automated monitor detecting anomalous behavior pages the on-call team. The responder declares the incident in Slack: `/incident declare "Suspected API credential leak"`.
3. **Containment (Immediate Mitigation):**
   - Revoke compromised access keys and invalidate active SSO sessions.
   - Modify AWS Security Groups to isolate affected EC2 instances into a quarantine VPC.
   - Apply WAF rate-limiting rules to block attacking IP subnets.
4. **Eradication & Forensics:** Capture memory dumps and snapshot EBS volumes for forensic analysis before terminating compromised compute instances. Patch the root vulnerability.
5. **Recovery & Verification:** Redeploy verified clean workloads from immutable CI/CD artifacts. Conduct continuous synthetic canary tests for 60 minutes.

6. **Post-Incident Review:** Convene a blameless postmortem within 48 hours to document timeline, root causes, and preventive action items.